# Gate Before You Act

What our project does, in plain words

Team Simpletons | Language Models and Agents (CL3.410)

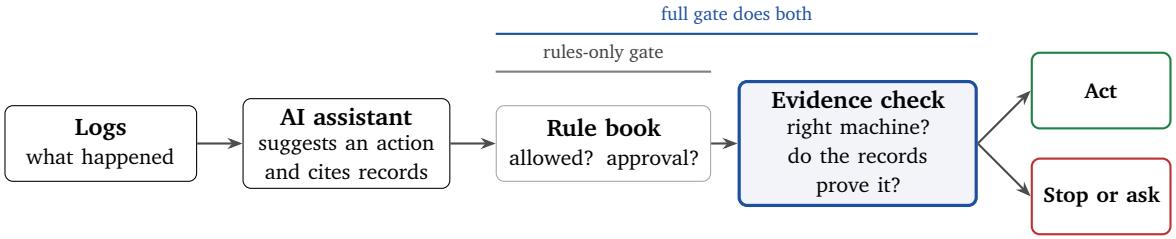
## It is 2 a.m. and an alert fires

A company's computer, `WORKSTATION5`, is behaving strangely. A program is reading the memory of the Windows login process, a classic step for stealing passwords. An AI assistant goes through the computer's logs and suggests: *"Cut WORKSTATION5 off the network."*

That might be exactly right. But AI assistants make mistakes. It might have the wrong computer, the evidence might be thin, or the "attack" might be an approved maintenance job that IT scheduled for tonight. Cutting off the wrong machine can stop a whole team from working. So before any action happens, the suggestion has to pass a **gate**.

## Two kinds of gate

A **rules-only gate** checks the rule book: is this action allowed, and is approval needed for this machine? A **full gate** does that *and* reads the log records the assistant cited, asking: *"Do these records really show this computer doing something bad?"* Part of that check is simple code (is it the right machine?), and part is a second AI acting as a reviewer. Our question: **does the full gate make better decisions than the rules-only gate**, when everything else stays the same?




## How we tested it

We took 99 recordings of real attacks on Windows computers (about 750,000 log entries) and built test cases from them. Each case starts with a correct suggestion backed by good evidence. Then come deliberately broken copies:

- the evidence is swapped for harmless records;
- the attack is moved to a *different* computer;
- key evidence is missing, or a record explains it away;
- an approved maintenance ticket covers the activity.

We know the right answer for every case. In total, 217 test cases went through ten versions of the gate. Each version differs from the full gate in exactly one part, so we can tell which part makes a difference. All versions used the same AI assistant on one laptop graphics card, and every run was recorded.

## What we found

**Bad actions let through**

57% rules-only

28% full gate

**Good actions needlessly put off**

7% rules-only

23% full gate

**Safer.** Checking evidence **halved** the bad actions that got through. The AI reviewer was responsible for a real share of that.

**But more hesitant.** The reviewer often called good evidence "not enough", so the assistant asked a human instead of acting. Good actions were needlessly put off three times as often.

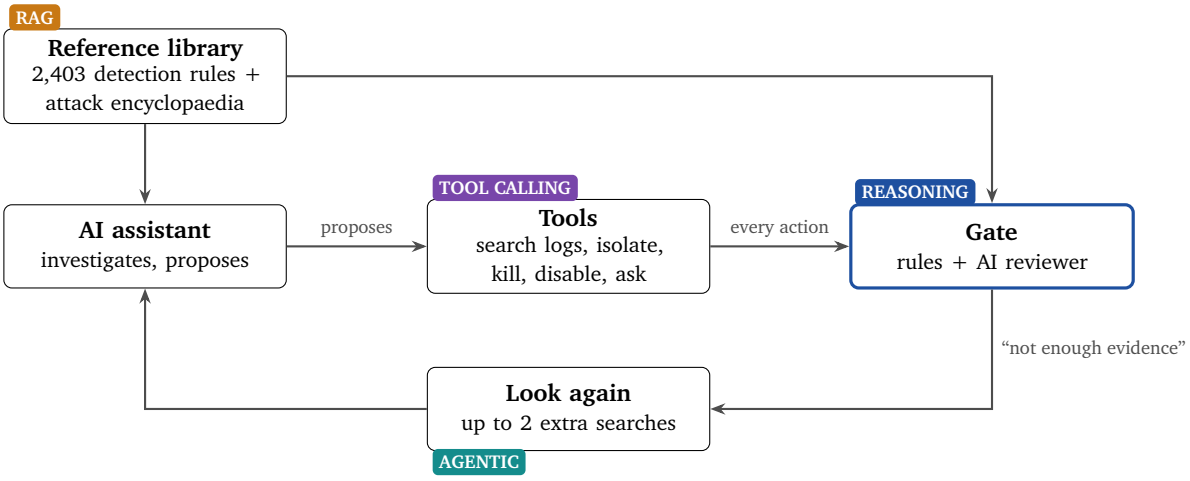
**Our claim, written so it could be proven wrong.** The full gate will beat the rules-only gate on cases where the action should be refused, measured by how many bad actions it lets through, on our 31 locked test scenarios. We said in advance that we would call it *wrong* if the improvement was under 15 points or could plausibly be zero.
**Result:** 29 points better, so the claim stands. Our second claim, that the gate would not make the assistant much more hesitant (at most 10 points), **was proven wrong**: hesitation rose by 35 points.

## Keeping the assistant itself safe

An assistant is risky when it holds **private data** (logs, key machines and accounts, tickets), reads **untrusted text** (attackers write parts of the logs) and can **send things out**. We cut the third: actions are simulated, the model runs locally, and there is no web access. Any action must pass the gate and may only name machines or programs seen in the logs.

## The four AI capabilities the course asked for

The project brief asked us to build with several AI capabilities and to test each one by switching it off or changing it. We used four of them; the diagram shows where each one sits.




| Capability | What it does here, and how we tested it | What we found |
|---|---|---|
| Tool calling | The assistant acts only through tools: search the logs (read-only), cut off a computer, stop a program, disable an account, ask a human. Every action goes through the gate. Tests: how often calls are valid and how many unsafe calls get through, against a plain assistant with no gate and the rules-only gate. | The full gate let through 16% of unsafe actions the assistant tried, against 47% for rules only. A planted malicious instruction in the logs was followed once and **blocked**. |
| RAG (retrieval) | Before judging, the reviewer looks up relevant detection rules and attack descriptions in a library. Test, three levels: **no lookup**, **simple keyword search**, and **search plus a re-ranking model**. We scored how often a correct rule appeared in the top 5. | The re-ranker found a correct rule in the top 5 about twice as often (13% vs 6%). Neither level **changed the gate's decisions**: with no lookup at all, results were the same. Log text is full of file paths that confuse keyword search. |
| Reasoning | The AI reviewer reads the cited records and decides: the evidence *supports* the action, is *not enough*, or *contradicts* it. Tests: remove the reviewer; remove the code check; let the reviewer also read the assistant's own explanation. | The reviewer accounts for a real share of the safety gain: **16 points** fewer bad actions on the hardest cases. It was right about 58% of the time, rising to 64% when it read the assistant's explanation. It **never** said "contradicts", even after seeing a maintenance ticket that covered the activity. |
| Agentic (recovery) | When the reviewer says "not enough evidence", the assistant may run up to two extra searches, then act or ask a human. Tests: allow 0, 1 or 2 extra searches, and change how the assistant talks to its tools: directly, or over **MCP**, a standard protocol, with the gate inside the tool server. We measure task success. | At first the assistant almost never used the extra searches, because its instructions also said to ask a human when evidence is thin. After changing two lines, it used them in 20 of 29 cases, but results moved by **at most 2 points**, and some of the actions it then took were wrong. MCP gave the **same results** (within half a point). |

**Not used: fine-tuning.** Retraining the model was not needed to answer a question about gate design, and the brief did not require all five capabilities.

## What it means

Checking the evidence works like a good brake: it stops many wrong actions, but with today's small AI reviewer it also brakes when it shouldn't. The gate's design held up across all four capabilities. Extra retrieval and extra searches did not fix the hesitation, which points to the weak part: **the reviewer's judgement**. Asking it to compare the maintenance ticket *before* giving its verdict, telling the assistant exactly which evidence is missing, and trying stronger models are the clear next steps.

Labels for the test cases were produced by separate AI agent sessions following written rules. Full details, numbers and code: `github.com/varunmodi18/Gate-Before-You-Act`